Job 3 — Industrialisation et supply chain : le paquet Debian

Compte rendu avec captures d'écran et réponses

Alexis Noiret · La Plateforme · Bachelor IT Cybersécurité · 27 octobre 2026

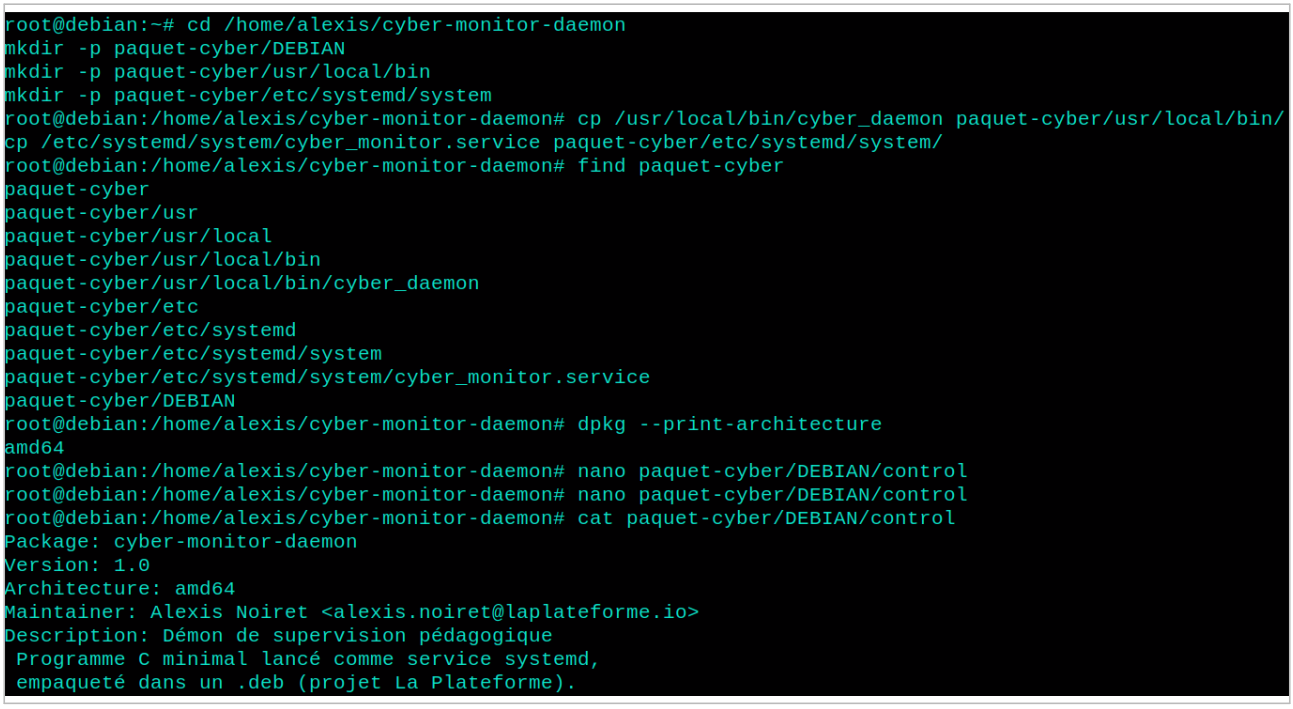
Environnement : Debian 13 (Trixie), dpkg

Principe

Un paquet **.deb** contient les fichiers à installer (ici le binaire et le fichier d'unité) ainsi que des métadonnées et des scripts. Le script **postinst** est exécuté automatiquement **en root** par dpkg juste après la copie des fichiers, sans aucune confirmation de l'utilisateur : c'est exactement le vecteur d'une attaque supply chain (MITRE ATT&CK T1543.002).

1 — Arborescence du paquet et fichier control

```
mkdir -p paquet-cyber/DEBIAN
mkdir -p paquet-cyber/usr/local/bin
mkdir -p paquet-cyber/etc/systemd/system
cp /usr/local/bin/cyber_daemon paquet-cyber/usr/local/bin/
cp /etc/systemd/system/cyber_monitor.service paquet-cyber/etc/systemd/system/
find paquet-cyber
dpkg --print-architecture
nano paquet-cyber/DEBIAN/control
```



```
root@debian:~# cd /home/alexis/cyber-monitor-daemon
mkdir -p paquet-cyber/DEBIAN
mkdir -p paquet-cyber/usr/local/bin
mkdir -p paquet-cyber/etc/systemd/system
root@debian:/home/alexis/cyber-monitor-daemon# cp /usr/local/bin/cyber_daemon paquet-cyber/usr/local/bin/
cp /etc/systemd/system/cyber_monitor.service paquet-cyber/etc/systemd/system/
root@debian:/home/alexis/cyber-monitor-daemon# find paquet-cyber
paquet-cyber
paquet-cyber/usr
paquet-cyber/usr/local
paquet-cyber/usr/local/bin
paquet-cyber/usr/local/bin/cyber_daemon
paquet-cyber/etc
paquet-cyber/etc/systemd
paquet-cyber/etc/systemd/system
paquet-cyber/etc/systemd/system/cyber_monitor.service
paquet-cyber/DEBIAN
root@debian:/home/alexis/cyber-monitor-daemon# dpkg --print-architecture
amd64
root@debian:/home/alexis/cyber-monitor-daemon# nano paquet-cyber/DEBIAN/control
root@debian:/home/alexis/cyber-monitor-daemon# nano paquet-cyber/DEBIAN/control
root@debian:/home/alexis/cyber-monitor-daemon# cat paquet-cyber/DEBIAN/control
Package: cyber-monitor-daemon
Version: 1.0
Architecture: amd64
Maintainer: Alexis Noiret <alexis.noiret@laplateforme.io>
Description: Démon de supervision pédagogique
 Programme C minimal lancé comme service systemd,
 empaqueté dans un .deb (projet La Plateforme).
```

Arborescence du paquet (find), architecture (amd64) et contenu du fichier control.

Les fichiers sont placés à leur **chemin final** dans le dossier du paquet : `paquet-cyber/usr/local/bin` devient `/usr/local/bin` sur la machine cible. Le dossier `DEBIAN` contient les métadonnées.

Fichier DEBIAN/control

```
Package: cyber-monitor-daemon
Version: 1.0
Architecture: amd64
Maintainer: Alexis Noiret <alexis.noiret@laplateforme.io>
Description: Démon de supervision pédagogique
 Programme C minimal lancé comme service systemd,
 empaqueté dans un .deb (projet La Plateforme).
```

- **Package** : nom du paquet, en minuscules, sans underscore.
- **Version** : numéro de version du paquet.
- **Architecture** : amd64, valeur confirmée par `dpkg --print-architecture` ; le binaire est compilé pour x86-64.
- **Maintainer** : nom et adresse de la personne qui maintient le paquet.
- **Description** : résumé sur la première ligne ; les lignes suivantes **commencent par un espace**, ce qui indique à dpkg qu'elles prolongent le champ.

2 — Le script post-installation (postinst)

```
nano paquet-cyber/DEBIAN/postinst
chmod 755 paquet-cyber/DEBIAN/postinst
ls -l paquet-cyber/DEBIAN/
dpkg-deb --build paquet-cyber
```



Script postinst, droits d'exécution (-rwxr-xr-x) et première construction du paquet.

```
#!/bin/sh
set -e

systemctl daemon-reload
systemctl enable --now cyber_monitor.service

echo "cyber-monitor-daemon installé : le service est actif."
exit 0
```

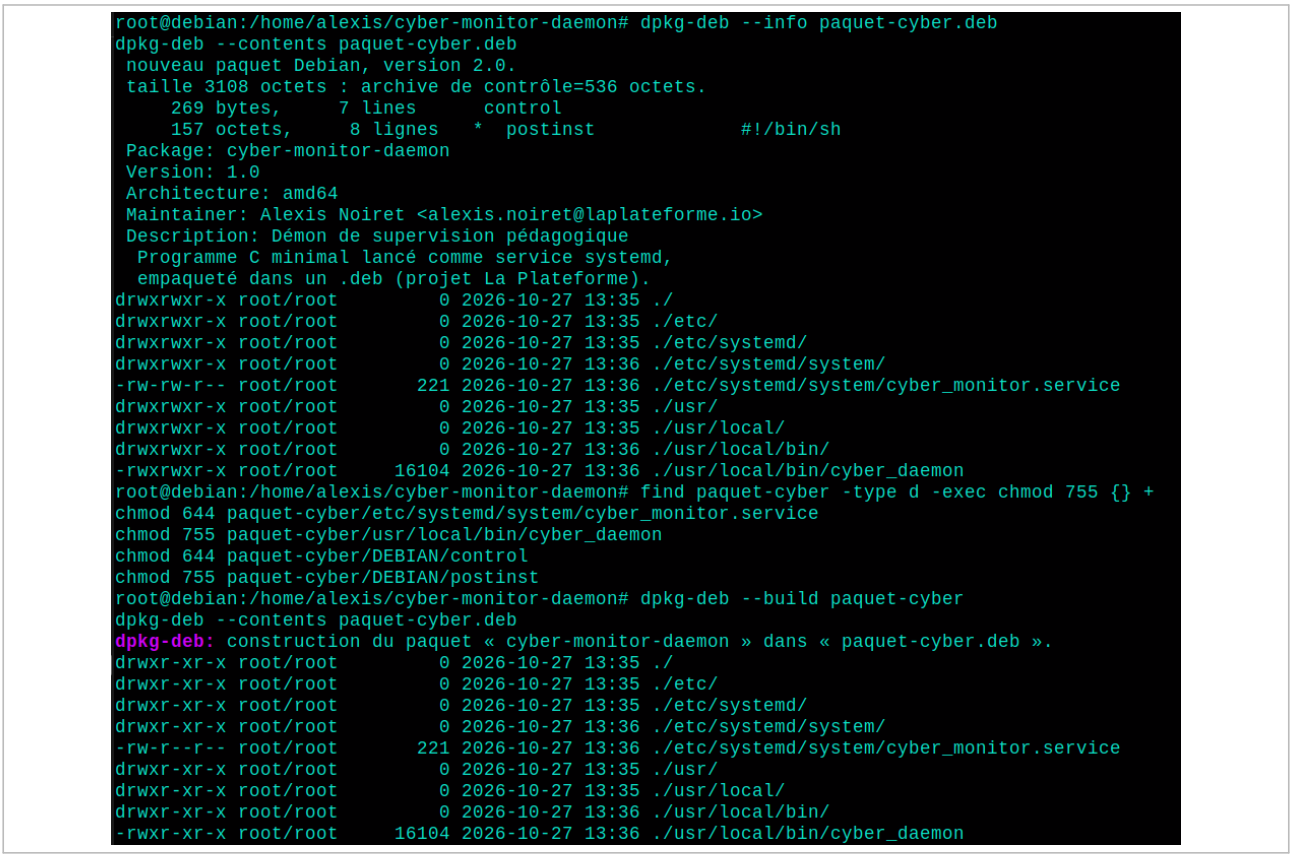
- **#!/bin/sh** : script shell classique ; cette ligne est obligatoire pour que dpkg sache l'exécuter.
- **set -e** : le script s'arrête dès qu'une commande échoue, pour qu'un problème soit visible au lieu de passer pour une installation réussie.
- **systemctl daemon-reload** : recharge la configuration de systemd pour qu'il découvre l'unité tout juste déployée par le paquet.

- **systemctl enable --now** : active le service au boot et le démarre immédiatement, sans action manuelle.
- **echo** : message confirmant le succès de l'installation. **exit 0** : fin avec le code de succès.

chmod 755 est indispensable : sans droit d'exécution sur le postinst, la construction du paquet échoue.

3 — Construction, inspection et correction des droits

```
dpkg-deb --build paquet-cyber
dpkg-deb --info paquet-cyber.deb
dpkg-deb --contents paquet-cyber.deb
```



Inspection du paquet, constat de droits trop larges (775/664), correction puis reconstruction.

dpkg-deb --info affiche les métadonnées et la liste des scripts (postinst, marqué d'une étoile car exécutable). **dpkg-deb --contents** liste les fichiers installés et leurs chemins. C'est aussi ce que fait un analyste pour examiner un paquet suspect **avant** de l'installer.

Correction des droits

La première construction montrait des dossiers en `drwxrwxr-x` (775) et un fichier de service en `-rw-rw-r--` (664), donc modifiables par le groupe. Ces droits seraient appliqués sur la machine cible. Les droits standards Debian ont donc été appliqués avant de reconstruire :

```
find paquet-cyber -type d -exec chmod 755 {} +
chmod 644 paquet-cyber/etc/systemd/system/cyber_monitor.service
chmod 755 paquet-cyber/usr/local/bin/cyber_daemon
chmod 644 paquet-cyber/DEBIAN/control
chmod 755 paquet-cyber/DEBIAN/postinst
```

Après reconstruction : dossiers en 755, service en 644, binaire en 755. Un paquet ne doit pas rendre un fichier système modifiable plus largement que nécessaire.

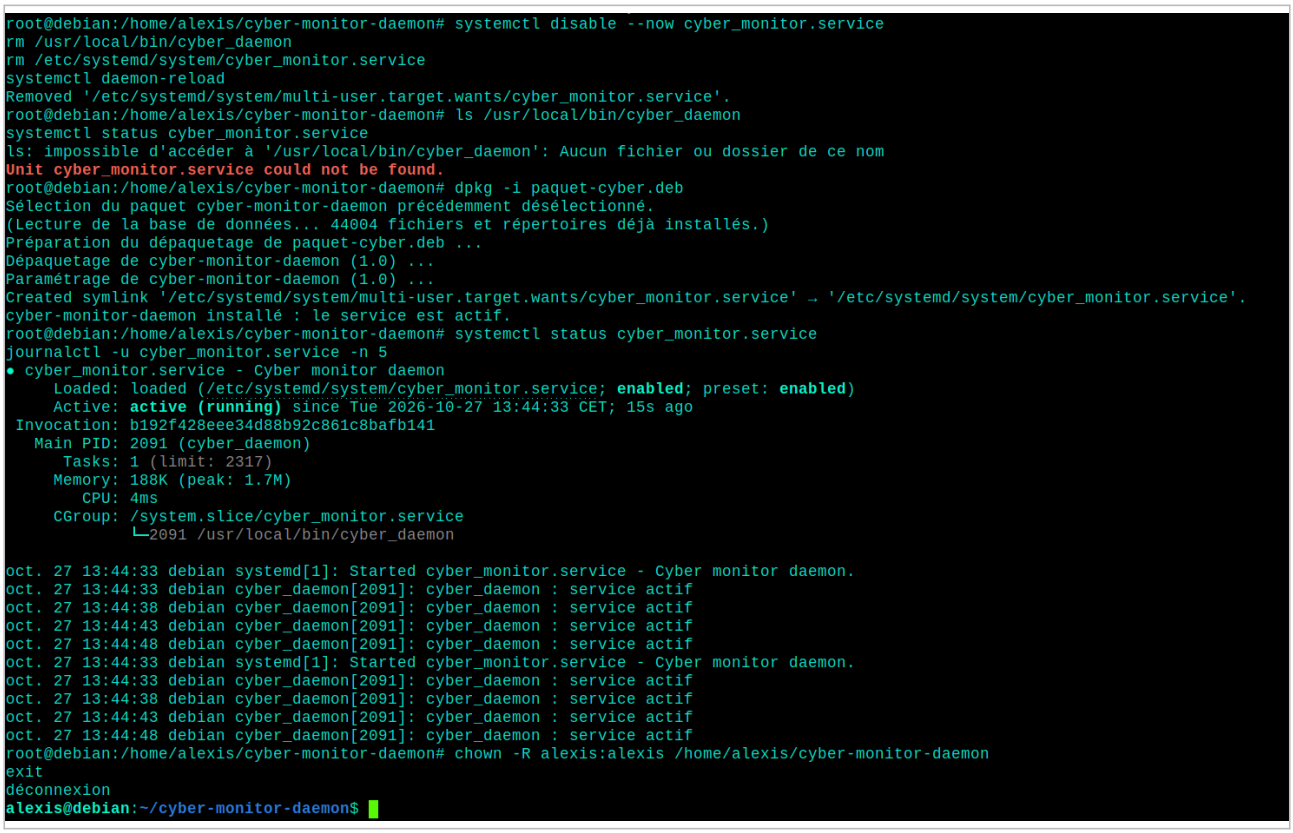
Étape 4 — Scénario de test et validation générale

La machine est d'abord remise dans son état initial (service désactivé et supprimé, binaire supprimé), puis le paquet est installé.

```
systemctl disable --now cyber_monitor.service
rm /usr/local/bin/cyber_daemon
rm /etc/systemd/system/cyber_monitor.service
systemctl daemon-reload
ls /usr/local/bin/cyber_daemon
systemctl status cyber_monitor.service

dpkg -i paquet-cyber.deb

systemctl status cyber_monitor.service
journalctl -u cyber_monitor.service -n 5
```



Remise à zéro, installation du paquet, puis vérification : le service démarre tout seul.

- **État initial** : le binaire est introuvable et systemd répond *Unit cyber_monitor.service could not be found* (résultats attendus).
- **Installation** : `dpkg -i` dépaquette les fichiers, puis le postinst crée le lien `multi-user.target.wants/` et affiche le message de confirmation.
- **Vérification** : `active (running)` et `enabled`, avec un nouveau PID (2091), et le message `cyber_daemon : service actif` toutes les 5 secondes dans le journal. Aucune action manuelle n'a été nécessaire.

Les lignes du journal apparaissent deux fois car `systemctl status` affiche déjà les dernières lignes du journal, que `journalctl -n 5` réaffiche ensuite.

Dernière étape avant le rendu : `chown -R alexis:alexis` sur le dossier du projet, car les fichiers du paquet avaient été créés en root, puis `exit` pour revenir à l'utilisateur normal.

Lecture supply chain / MITRE ATT&CK T1543.002

En une seule commande, un programme s'est installé, activé et lancé en root, avec une persistance au démarrage, sans confirmation de l'utilisateur. Un paquet piégé fonctionne de la même façon : le postinst exécute ce que son auteur a voulu, avec tous les droits.

Pistes de défense :

- n'installer que des paquets provenant de dépôts de confiance, dont l'intégrité est vérifiée par signature ;
- inspecter un .deb inconnu avant de l'installer (`dpkg-deb --info`, `--contents`, lecture des scripts) ;
- superviser les créations de services avec `journalctl`, la liste des unités activées et les modifications de `/etc/systemd/system/`.